Xác thực và phân quyền

Xác thực (authentication) trả lời câu hỏi: **bạn là ai?** Phân quyền (authorization) trả lời: **bạn được làm gì?**

Hệ thống web thường xác thực một lần khi đăng nhập rồi gửi kèm token trong mỗi yêu cầu tiếp theo.

JSON Web Token (JWT)

JWT gồm ba phần ngăn cách bởi dấu chấm: header, payload và signature.

- Header: thuật toán ký, ví dụ HS256.
- Payload: thông tin người dùng như mã, vai trò, thời hạn.
- Signature: chữ ký giúp máy chủ phát hiện token bị sửa.

Mã trạng thái 401 và 403

401 Unauthorized: chưa đăng nhập hoặc token không hợp lệ.

403 Forbidden: đã đăng nhập nhưng không đủ quyền, ví dụ sinh viên gọi API chỉ dành cho giảng viên.

Lưu mật khẩu an toàn

Không bao giờ lưu mật khẩu dạng văn bản thường. Hãy băm một chiều có salt bằng BCrypt hoặc Argon2.

Khi đăng nhập, máy chủ băm mật khẩu nhập vào rồi so sánh với giá trị đã lưu.